SNAPSMACK OPERABILITY AUDIT

# OPAUDIT 033 — Shared updater temporary directory caused a false SMACKBACK breach

> **DRAFT — unpublished.** Prepared from the measured Strathmore incident, SS-1284, and the independently reviewed source repair. The repair is merged for a future release but is not deployed.

| Field | Value |
|---|---|
| Audit ID | 2026-11-11-033 |
| State | OPEN. Cause and source repair are verified; deployment and installed acceptance remain. |
| Scope | A shared update workspace across virtual hosts, a silently skipped file-integrity re-baseline, and the scheduled verifier that converted stale baseline data into a false LOCKOUT. |
| Ticket | SS-1284 — Updater temp directory is shared across virtual hosts. |

## WHAT HAPPENED

After Strathmore updated from 0.7.991D to 0.7.992D, SMACKBACK reported six shipped files as tampered and placed the site in LOCKOUT. The files had not been maliciously changed: five matched clean 0.7.992D peers byte-for-byte, and the sixth was a legitimate protected per-install file. The installed version was 0.7.992D.

The update log recorded a missing update package during the staged update, and it did not contain the normal “Disk baseline set” notice. The first breach arrived later, when scheduled verification compared the legitimately updated files with the stale pre-update baseline.

## MEASURED CAUSE

Every virtual host in the shared container used the same update workspace. Concurrent or rapid fleet updates could delete or replace another site's staged package. The finalize path treated a missing package as a reason to skip the SMACKBACK re-baseline while still completing version finalization. The hub path also discarded a failed re-baseline result.

That produced a three-part failure:

1. unrelated sites shared mutable update state;
2. a missing package silently skipped the integrity baseline refresh; and
3. the scheduled verifier ran during or immediately after the update and treated the stale baseline as a breach.

## RECOVERY EVIDENCE

The extracted 0.7.992D manifest matched 489 of 491 on-disk files exactly, with zero missing files. The two differences were protected per-install files. The release public key matched clean peers, although its protected template remained older. These facts supported a controlled baseline rebuild; they did not justify restoring the six files, which would have regressed correct update content.

No audit claim is made that every file was independently proven safe beyond the manifest and peer comparisons recorded above.

## SOURCE REPAIR

The SS-1284 repair gives each installation a stable workspace derived from its install root, so staged requests for one site share a directory while different virtual hosts do not. It removes the incorrect package-exists gate from the on-disk baseline refresh, reports a missing package as a failure, withholds automatic breach clearing when the update cannot be trusted, and returns the baseline outcome to the hub.

A separate repair makes the scheduled verifier respect the update maintenance lock, while retaining the existing stale-lock ceiling so an abandoned lock cannot suppress verification indefinitely.

The SS-1284 regression executes 46 checks. Claude Code reported mutation checks against the unfixed tree for earlier revisions of the branch; this audit did not independently repeat that mutation run against the final tip. Codex's different-agent review at `6c45b931` passed the final regression and rendered warning state, but it was not a live 27-root uniqueness sweep. The repair derives a stable key from each install root by source design; cross-vhost isolation remains part of the acceptance work below. The repairs are in source for the next release; they are not installed acceptance.

## WHAT REMAINS OPEN

1. Deploy the repair through the normal owner-controlled release path.
2. Run two overlapping staged updates on isolated sibling virtual hosts and prove their workspaces and packages remain distinct.
3. Prove each update refreshes its own baseline and reports the outcome to the hub.
4. Prove scheduled verification skips an active update, then runs normally after the lock clears.
5. Verify Strathmore remains clean after controlled recovery and the repaired release.

## WHAT TO CHECK IN YOUR OWN PROJECT

1. Do different sites or tenants ever share a mutable update or extraction directory?
2. Is the workspace stable for every stage of one update but unique to the installation performing it?
3. Can a missing staged package silently skip a security or integrity step while the update still reports success?
4. Does scheduled monitoring respect an update lock without allowing an abandoned lock to disable checks forever?
5. Does the central dashboard receive and display the real integrity result instead of assuming success?

## WHAT THIS AUDIT DOES NOT CLAIM

- It does not claim malicious tampering caused the Strathmore incident.
- It does not claim the repair is deployed or live-verified.
- It does not claim the controlled overlapping-update acceptance test has run.
- It does not close SS-1284; source verification is only one step in its lifecycle.

Prepared by Codex with AI assistance. Status: **OPEN**.